PQMigrate Multi Engine Integration Proposal

Technical feasibility operating model and commercial validation

PQMigrate project team and faculty reviewers | 21 October 2026

Fund a staged research integration, beginning with CryptoScan and Semgrep. Treat Where's Crypto? and CRYLOGGER as optional specialist workstreams until licensing, compatibility and deployment tests pass. The proposed platform is feasible as an evidence and review system; enterprise readiness and market superiority are not established.

Decision requested

Authorize a two-week feasibility stage to freeze supported environments, confirm component rights and define the evidence contract. Release subsequent engineering effort only after each integration gate is satisfied. Do not fund an unconditional four-tool commercial bundle or advertise a top-five-percent market position at this stage.

What the resulting product would do

A user would select an authorized repository or artifact, choose available analysis workers, inspect a unified asset inventory, and follow each proposed operation or migration plan back to its source evidence. The interface would expose unresolved identities, conflicting observations and failed scans alongside findings. Reviewers could approve an interpretation, request context, or reject a proposed link before a versioned plan is exported.

PQMigrate's prospective value is the review and reasoning layer: source-level roles, traceable blockers and explainable plan conditions. Combining detectors alone does not create that value. The core product must keep inventory, inferred role, observed execution and authorized transformation distinct.

Present evidence and proposed capabilities

Present evidence	Proposed extension
Bounded Python and Go prototype; synthetic Python RSA pilot described in the paper and report.	An adapter contract and review workflow that retain evidence from several analysis modes.
Pinned Semgrep runner and unscored raw archives exist [18].	CryptoScan integration, binary import and controlled Android runtime observation are future work.
Independent real-code gold labels and accuracy comparisons remain pending.	Locked multi-track evaluation, customer workflow pilots and operational hardening.

Commercial conclusion

There are credible discovery and migration-planning needs, but established vendors already address overlapping workflows. The investable hypothesis is a focused, auditable developer and reviewer workflow with measurable reductions in investigation effort. Neither willingness to pay nor superiority over 95 percent of tools has been demonstrated.

2 Integration feasibility and component rights

Use documented interfaces and permitted source extensions first. Public GitHub visibility and popularity do not establish maintenance quality, compatibility or redistribution rights [16]. The feasibility judgments below are engineering assessments, not measured performance scores.

Four component workstreams

Component	Adapter and adaptation	Principal gate
CryptoScan	Import JSON or SARIF inventory candidates; retain native rule identity and location; translate into the evidence contract [1].	Lower integration risk. Apache-2.0 is published; verify notices and dependency terms for the pinned release [2].
Semgrep CE	Extend the existing process runner with versioned custom crypto rules and a stable JSON/SARIF adapter [3,18].	Lower to moderate risk. Engine LGPL-2.1 terms and rule-pack rights are separate [4,5].
Where's Crypto?	Import binary primitive candidates, addresses and configuration from an IDA analysis session; retain uncertain source links [6,7].	High risk. Legacy SDK/toolchain compatibility, explicit implementation license and IDA rights must be resolved.
CRYLOGGER	Import sanitized cryptolog events from an isolated Android/Java test worker; retain session and workload coverage [8].	High risk. Modern Android support, emulator reproducibility and log minimization need validation; repository MIT does not license every dependency [9].

Adaptation policy

Pin a source commit, dependency manifest, build recipe and output-schema version for every component. Read and test the relevant implementation against documented behavior before modifying it. Keep a narrow downstream patch set and a replay suite for future upstream changes. Do not rebrand upstream detection as new cryptographic analysis.

For a service or competing product, use original PQMigrate rules or separately authorized packs: Semgrep's vendor-rule license restricts distribution and service use [5]. The inspected Where's Crypto? repository did not establish an explicit implementation license; its paper describes the implementation as open source [7], but commercial reuse still needs clear component rights. Until resolved, keep the binary workstream out of the distributable product.

Scope consequence

CRYLOGGER does not directly extend Python/Go runtime coverage. Its Android/Java track needs its own artifacts, labels and tests. Likewise, binary primitive classification does not by itself prove whether an application signs, transports keys or encrypts arbitrary data. Broader input coverage must not be presented as broader proven semantic coverage.

3 Target architecture and operability

The proposed system is a customer-controlled analysis and review plane. Expensive or execution-bearing analysis is optional and isolated. The default source workflow reads code without running the target application.

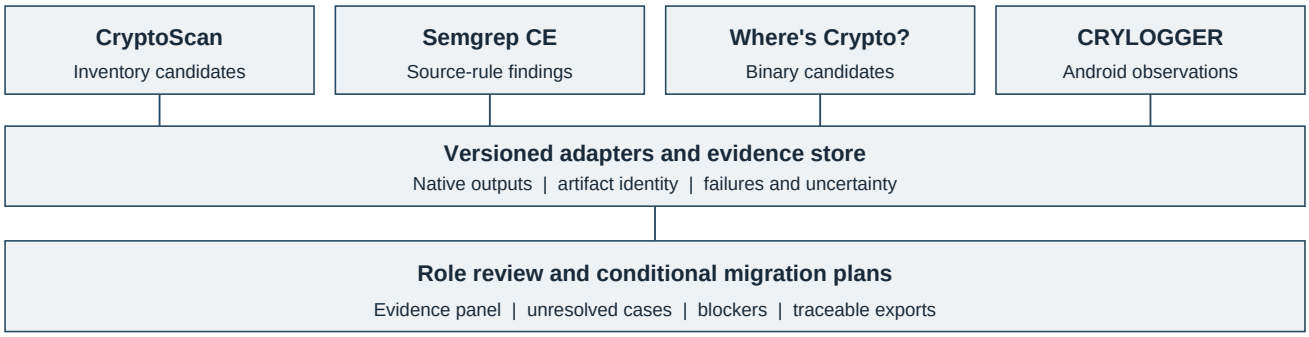

Figure 1 Proposed evidence flow and review workflow

Evidence contract

Each observation records the artifact or repository commit and hash, source span or binary address, tool and rule version, configuration, raw-result reference, execution status and evidence kind. Runtime events additionally identify the workload and session. Preserve unknown values; a missing observation is not a negative label.

Correlate only through defensible identity links, such as matching builds and symbols. Keep unresolved cross-artifact links separate. Exact duplicates may share an asset view, while all native observations remain recoverable. Agreement between related rule engines is not independent ground truth.

Daily workflow

Queue scans in CI or an analyst workspace; import completed observations; inspect differences from the previous pinned run; route uncertain cases to an owner; review operation and application role; then export a conditional migration plan, SARIF finding or CBOM. Integration with ticketing and asset ownership is a proposed product feature, not a delivered connector.

Operational controls

Separate source, binary and runtime worker pools with per-job limits, cancellation and explicit failure states. Use tenant isolation, role-based access, retention controls and audit logs before external pilots. Do not collect private keys or plaintext merely to improve observability: minimize and redact runtime parameters before ingestion. Keep customer code and artifacts local unless export is explicitly configured.

Source scanning can begin with modest developer infrastructure. Binary analysis requires a supported disassembler environment; Android runs require emulator/AOSP capacity and exercise authorized workloads. These dependencies make four-engine operation more costly than a single CLI scan. Production SLOs require measured workloads and are not promised here.

4 Competitors and defensible positioning

Vendor descriptions establish documented scope, not comparative effectiveness. All entries below are based on primary product documentation checked on 21 October 2026. No unsupported feature absence or numerical ranking is inferred.

Competitive landscape

Alternative	Documented overlap	Implication for PQMigrate
IBM Guardium Cryptography Manager and Quantum Safe Explorer	Discovery, inventory, dependency and ownership context, plus related remediation capabilities [10].	Enterprise migration management is an existing category; compare reviewer workflow and integration effort directly.
SandboxAQ AQtive Guard	Inventory of operations, keys, certificates and connected assets [11].	Operation visibility alone is not a unique differentiator. Test whether source-linked reasoning improves review.
Keyfactor AgileSec	Crypto inventory enriched with usage, ownership, dependencies and risk [12].	Ownership and context must be implemented well, not claimed as a novel idea.
QuSecure QuProtect	Continuous discovery and inventory with operational rollout context [13].	Network and estate workflows are a different scope from bounded source-role review.
CryptoScan and Semgrep CE	Inventory and custom source rules are accessible alternatives and proposed components [1,3].	The fused system must add measurable value beyond running and aggregating these engines.

Proposed initial position

Start with application-security engineers and migration consultants who review source-level cryptographic intent. Offer a narrow, reproducible evidence package with visible uncertainty, versioned decision rules and practical export. A private deployment option and a small integration surface could be useful, but customer interviews must establish whether these are purchase criteria.

The strongest research comparison is the existing resolver and each source engine separately versus the fused workflow on the same locked source cases. Commercial suites require separate product trials and matching use cases; public descriptions cannot support claims about their false positives, review cost or safety.

What we can say now

PQMigrate proposes an inspectable migration-review layer across complementary evidence sources. It has not demonstrated superiority over enterprise incumbents, four integrated production engines, safe automatic migration, or a market percentile. A broader feature list is not a substitute for a validated task advantage.

5 Validation plan and the 95 percent question

There is no evidence that the proposed tool is better than 95 percent of available products. A defensible claim must name the task, comparison population, eligible versions, metric and uncertainty. Ninety-five percent precision, a ninety-five-percent confidence interval and a ninety-fifth-percentile market rank are different quantities.

Evaluation tracks

Track	Ground truth and comparisons	Report separately
Source	Independent eligible reviewers; separate calibration; frozen assigned units; locked original labels and adjudication. Compare each source engine, their union, current resolver and fused system.	Presence, role, useful answer coverage, correctness among answers, abstention and failure counts.
Binary	Known compiled fixtures plus held-out binaries with traceable primitive truth. Record compiler, optimization, architecture, symbols and analysis configuration.	Primitive classification, localization and uncertain source correspondence; not inferred role accuracy.
Runtime	Authorized Android workloads with explicit expected observations and exercised paths. Separate observation tests from API-misuse checks.	Events observed, workload coverage, missed exercised events, instrumentation overhead and failures.
Reviewer workflow	Counterbalanced tasks on comparable cases; preserve original outcomes; measure effort and recommendation labels independently.	Review time, decisions corrected, unresolved cases and recommendation correctness.

Fairness and reproducibility

Freeze versions, configurations, rule sets and scoring before held-out evaluation. Keep related repositories, forks and duplicated snippets within a partition. Preserve parse failures, crashes, timeouts and unsupported targets; publish full-scope accounting as well as eligible-subset scores. A tool's no-match is not automatically a gold negative. Candidate-selected anchors cannot establish recall of missed operations.

Use paired comparisons on shared cases and uncertainty procedures that respect repository dependence. Select the primary metric and practical improvement margin before inspecting held-out results. Component ablations must rerun the analysis, not merely hide output fields. Retain unfavorable outcomes and failure ledgers.

Claim gate

A successful study may support a scoped statement such as improved role-review outcomes against named baselines on a defined held-out corpus. Testing a few selected tools does not establish that the product beats 95 percent of the market. A market-percentile claim requires a justified market population or representative sampling design and comparable measurements across that population. Until then, use a capability hypothesis rather than a superiority claim.

6 Delivery plan resources and release gates

A 26-week research prototype is a planning estimate, conditional on four full-time-equivalent contributors, usable source access, and timely component-rights decisions. Part-time academic work extends the schedule. Enterprise hardening and customer pilots are a separate subsequent stage.

Proposed milestones

Period	Deliverable	Exit evidence
Weeks 1 to 2	License and compatibility inventory; frozen adapter schema; representative fixtures.	Written component disposition and reproducible smoke-test plan. Stop blocked distribution paths.
Weeks 3 to 8	CryptoScan and Semgrep adapters; raw-output retention; source-only review prototype.	Every input accounted for; deterministic normalization; schema-change and failure replay tests.
Weeks 9 to 14	Evidence correlation, reviewer queue, conditional plan export and independently managed labeling workflow.	Auditable identity links and uncertainty; blind review process and frozen test partitions.
Weeks 15 to 20	Separate IDA and Android proof-of-concept imports where prerequisites pass.	Supported environment recipe, controlled artifacts and no unapproved redistribution or execution.
Weeks 21 to 26	Locked multi-track evaluation and limited operator study.	Reproducible comparison, disclosed limits and a go/no-go decision for pilots.
Months 7 to 12	Conditional external pilots and hardening.	Customer-specific scope, measured reliability and review effort; no automatic general rollout.

Resource model

Planning capacity is approximately 24 person-months over six months: two analysis/integration engineers, one platform engineer, and one combined research/QA lead. Allocate specialist review time for cryptography, Android, IDA and licensing. This is a staffing assumption, not a labor-market quote or a delivery commitment.

Budget should be calculated from approved loaded staff rates, workstation and CI use, binary-analysis licenses, emulator capacity, security review and customer onboarding. Use a sponsor-approved contingency allowance. Cloud, licensing, support and sales costs have not been measured; no revenue or market-size forecast is asserted.

Release gate

Proceed to a limited pilot only when component rights, reproducible deployment, failure handling, data minimization, independent evaluation and an accountable operator are established. If binary rights or runtime compatibility fail, ship the source-review scope and keep the blocked component optional rather than concealing the gap.

7 Market demand and commercial validation

The category has credible policy and operational demand signals. Those signals justify customer discovery; they do not establish a market size, purchasing budget or product-market fit for PQMigrate.

Evidence of a problem worth testing

UK NCSC guidance recommends discovery and planning by 2028, highest-priority migration activities by 2031 and completion by 2035 [14]. The European Commission has published a coordinated PQC migration roadmap [15]. NIST NCCoE treats discovery and interoperability as distinct workstreams [17]. These sources support demand for inventory and planning expertise within their contexts; they are not universal legal deadlines or endorsements of PQMigrate.

Existing enterprise vendors demonstrate an active supply of cryptographic management products, but their existence alone does not quantify customer demand. The unresolved commercial question is whether a specific application-review workflow is painful enough for customers to adopt and pay for another platform.

Customer hypotheses

Proposed segment	Problem to validate	Evidence required
Application security teams	Mapping discovered crypto to application intent and an accountable owner takes too much analyst time.	Current workflow, review effort, error costs, data-access constraints and budget owner.
Migration consultancies	Repeatable evidence packages could improve consistency across client engagements.	Repeat-use cases, acceptable deployment model and willingness to fund a defined pilot.
Software vendors with regulated customers	Customers request defensible crypto inventories and migration explanations.	Actual procurement requests and measurable acceptance criteria; no assumed mandate.

Proposed validation program

Target 12 structured interviews and three design-partner pilots as research goals, not existing traction. Record task frequency, current tools, time to resolve a finding, data residency needs, integration friction and purchasing authority. Include organizations that already use a competitor. Use approved participant consent and data-access arrangements.

Before scaling, require repeat use on a second project, measurable workflow benefit against the existing process, an identified economic buyer and at least one paid or formally budgeted pilot. Test private deployment, annual support and consulting-assisted adoption as alternatives; set prices only after customer and cost evidence. Keep an open evidence schema to reduce adoption friction.

Decision

Proceed with the source-first feasibility stage. Preserve the four-engine architecture as a conditional roadmap. Stop broad superiority marketing and defer product-wide claims until independent comparative evidence and customer validation justify them.

8 References and evidence basis

Primary documentation reviewed on 21 October 2026. Vendor pages describe advertised capabilities, not independently verified effectiveness. Project estimates and acceptance gates in this proposal are proposed assumptions.

[1] CSNP, CryptoScan repository and README. https://github.com/csnp/cryptoscan

[2] CSNP, CryptoScan Apache License 2.0. https://raw.githubusercontent.com/csnp/cryptoscan/main/LICENSE

[3] Semgrep, Community Edition. https://semgrep.dev/products/community-edition/

[4] Semgrep 1.181.0, LGPL 2.1 license. https://raw.githubusercontent.com/semgrep/semgrep/v1.181.0/LICENSE

[5] Semgrep, Rules License version 1.0. https://semgrep.dev/legal/rules-license/

[6] Where's Crypto, implementation README. https://raw.githubusercontent.com/wheres-crypto/wheres-crypto/master/README.md

[7] C. Meijer, V. Moonsamy, and J. Wetzels, Where's Crypto, USENIX Security 2021, pp. 555-572. https://www.usenix.org/conference/usenixsecurity21/presentation/meijer

[8] L. Piccolboni et al., CRYLOGGER implementation README. https://raw.githubusercontent.com/lucapiccolboni/crylogger/master/README.md

[9] CRYLOGGER MIT License. https://raw.githubusercontent.com/lucapiccolboni/crylogger/master/LICENSE

[10] IBM, Guardium Cryptography Manager. https://www.ibm.com/products/guardium-cryptography-manager

[11] SandboxAQ, AQtive Guard inventory documentation. https://docs.aqtiveguard.com/inventory/

[12] Keyfactor, cryptographic discovery and inventory. https://www.keyfactor.com/products/cryptographic-discovery-inventory/

[13] QuSecure, cryptographic discovery and inventory. https://www.qusecure.com/quprotect/cryptographic-discovery-and-inventory/

[14] UK NCSC, Timelines for migration to post-quantum cryptography. https://www.ncsc.gov.uk/guidance/pqc-migration-timelines

[15] European Commission, Coordinated implementation roadmap for the transition to PQC. https://digital-strategy.ec.europa.eu/en/library/coordinated-implementation-roadmap-transition-post-quantum-cryptography

[16] GitHub Docs, Licensing a repository. https://docs.github.com/en/repositories/managing-your-repositorys-settings-and-features/customizing-your-repository/licensing-a-repository

[17] NIST NCCoE, Migration to Post-Quantum Cryptography. https://www.nccoe.nist.gov/applied-cryptography/migration-to-pqc

[18] PQMigrate, pinned unscored Semgrep baseline, revision 72dc7445c531bae2a54e488a5a97cf14c141bf90. https://github.com/Ratneshp1122/PQMigrate/tree/72dc7445c531bae2a54e488a5a97cf14c141bf90/experiments/semgrep_baseline